Exercise 03 — Post-Exploitation & Privilege Escalation

Overview

Date: 2026-03-07 **Attacker Machine:** Kali Linux (192.168.64.3) **Target Machine:** Basic Pentesting 1 / vtcsec (192.168.64.7) **Objective:** Simulate post-exploitation activity from a reverse shell and detect it in Splunk using TTY and sudo log analysis.

1. Objective

After gaining initial access via the ProFTPD backdoor in Exercise 02, this exercise simulates what an attacker does next — enumerating the system, reading sensitive files, and checking privilege levels. A key goal for a SOC analyst is detecting that an attacker is operating via a **reverse shell** rather than a legitimate interactive session. The TTY=unknown indicator in sudo logs is one of the most reliable signatures of this activity.

2. Attack Execution

Access Method

Root shell obtained via Metasploit ProFTPD backdoor exploit (see Exercise 02).

Post-Exploitation Commands

The following commands were executed from the reverse shell to simulate attacker enumeration:

```
# Confirm access level
whoami
# Check user and group IDs
id
# Enumerate all system users
cat /etc/passwd
# Attempt to read password hashes
cat /etc/shadow
# Check sudo privileges
sudo -l
```

What Each Command Reveals to an Attacker

Command	Purpose
whoami / id	Confirms root access and group memberships
cat /etc/passwd	Lists all user accounts — useful for lateral movement
cat /etc/shadow	Attempts to read password hashes for offline cracking
sudo -l	Lists all commands available via sudo — maps privilege paths

3. Log Evidence

Key Finding — TTY=unknown

The most significant log entry captured:

Mar 7 11:30:21 vtcsec sudo: root : TTY=unknown ; PWD=/ ; USER=root ; COMMAND=list

Why TTY=unknown is Critical

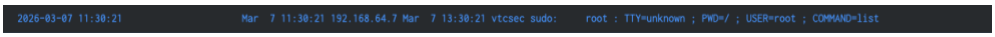
Indicator	Normal Admin Session	Reverse Shell
TTY value	pts/0, tty1, etc.	unknown
PWD	Home directory or specific path	/ (root directory)
Session type	Interactive	Non-interactive

A legitimate administrator logging in via SSH or console always has a TTY assigned. TTY=unknown means the command was executed from a **non-interactive shell** — the exact signature of a Metasploit reverse shell payload.

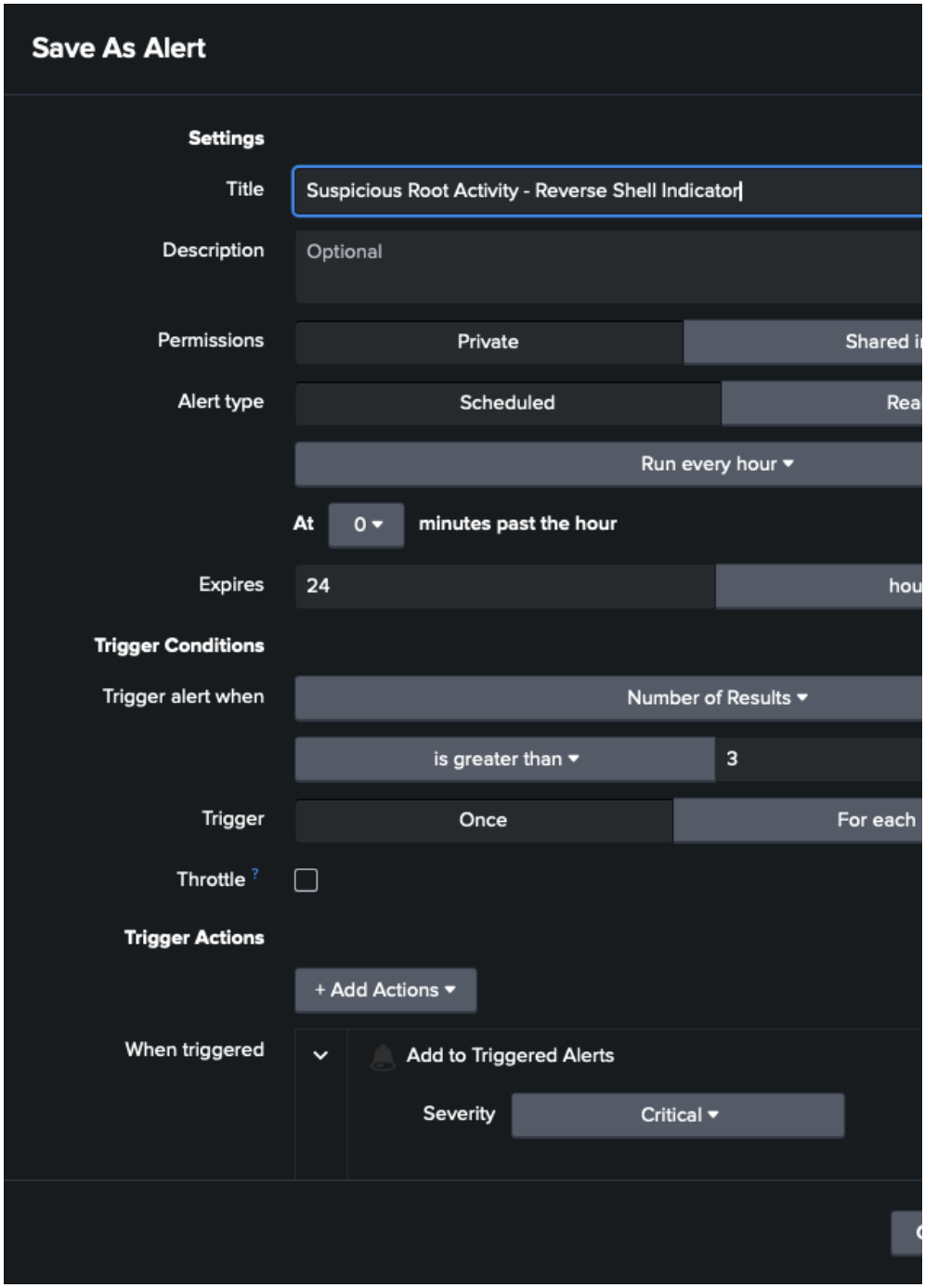
Background Noise vs Attack Activity

Multiple CRON job entries were present in the logs at regular intervals — these are normal scheduled tasks and were filtered out during analysis, demonstrating the importance of distinguishing legitimate system activity from malicious behavior.

Screenshots

File	Description
screenshots/exercise03-tty-unknown-focused.png	
screenshots/exercise03-suspicious-command-detected.png	

screenshots/exercise03-splunk-alert-saved.png



4. Detection

SPL Query — Reverse Shell Indicator

```
index=main host="192.168.64.7"
| search "TTY=unknown"
| stats count as suspicious_commands by host
| where suspicious_commands > 0
```

Query logic:

- Searches for any sudo activity executed from a non-interactive shell
- Counts occurrences per host
- Triggers on ANY occurrence — threshold of 0 because there is no legitimate reason for TTY=unknown in a normal environment
- Returned a count of **1** during this exercise

Splunk Alert Configuration

Setting	Value
Alert Name	Suspicious Root Activity - Reverse Shell Indicator
Schedule	Every hour
Trigger Condition	Number of results > 0
Trigger	Once
Expiration	24 hours
Severity	Critical
Action	Add to Triggered Alerts

> **Analyst note:** Unlike Exercise 01 where we set a threshold of 3 to filter noise, this alert triggers on a single occurrence. TTY=unknown is not generated by any legitimate admin activity — even one instance warrants immediate investigation.

5. Response Notes

If this alert fired in a real SOC environment, the following steps would be taken:

1. **Immediate escalation** — Critical severity, escalate to Tier 2/IR team immediately
2. **Identify the process** — Which process spawned the non-interactive shell? Check parent process IDs
3. **Review full session** — What other commands were run during this session? Check auth logs and bash history
4. **Check for persistence** — Did the attacker add SSH keys, new users, cron jobs, or web shells?
5. **Review sensitive file access** — Were /etc/passwd or /etc/shadow accessed? If shadow was read, assume passwords are compromised
6. **Isolate the system** — Remove from network immediately to prevent lateral movement
7. **Forensic imaging** — Preserve system state before remediation for evidence

6. Key Takeaways

- TTY=unknown in sudo logs is a near-certain indicator of reverse shell activity
- Post-exploitation enumeration leaves detectable traces even when the attacker has root
- Not all alerts need thresholds — some indicators are suspicious enough to trigger on a single occurrence
- Distinguishing CRON background noise from attacker activity is a core SOC analyst skill
- The combination of TTY=unknown + PWD=/ + USER=root creates an extremely high confidence detection with virtually no false positives